

訪客臨時令牌核發 API 的規範

基本資訊

項目	內容
實作檔案	api/大概是 API 吧/control_device/issue_guest_token_demo.py
方法	POST / CGI stdin
Endpoint	/control_device/issue_guest_token_demo.py
Content-Type	application/json; charset=utf-8
App 互動	Admin App 呼叫 API 產生 GUEST_ 明文令牌。
ESP 互動	無直接 ESP 封包；後續由設備控制 API 轉成 MQTT 控制封包。

POST Request Parameters

欄位	型別	Required	說明
created_by	string	true	核發者 user_id，通常為 Admin。
family_id	integer	true	令牌作用場域。
device_id	string	true	令牌可控制的指定設備。
allowed_actions	array[string]	true	允許動作，例如 ["UNLOCK"]。
expires_in_minutes	integer	false	令牌有效分鐘數。
max_uses	integer	false	最多使用次數。

App → API Request Packet

```
{
  "payload": {
    "created_by": "admin_001",
    "family_id": 12,
    "device_id": "ESP32_LOCK_001",
    "allowed_actions": [
      "UNLOCK"
    ],
    "expires_in_minutes": 10,
    "max_uses": 1
  }
}
```

Processing Rules

編號	規則
1	讀取 payload 並檢查 created_by、family_id、device_id、allowed_actions。
2	確認 device_id 存在且屬於 family_id。
3	產生內部 token_id = GT_xxx 與明文 guest_token = GUEST_xxx。
4	以 SHA-256 計算 token_hash，只保存 token_hash，不保存明文 guest_token。
5	寫入 guest_tokens，used_count=0、revoked=0。
6	回傳明文 guest_token 給 App，僅本次回應顯示。

API 對 SQL 寫入內容

資料表	寫入 / 更新欄位	觸發時機與說明
guest_tokens	INSERT token_id, token_hash, family_id, device_id, allowed_actions, expires_at, max_uses, used_count, revoked, created_by, created_at	核發訪客短效令牌時寫入。token_hash 必須 UNIQUE。
devices	SELECT device_id, family_id, status, pairing_status	確認目標設備存在且屬於指定場域。
audit_logs	可新增 TOKEN_ISSUED 事件	目前測試版重點是 guest_tokens；正式版建議記錄令牌核發稽核。

API → App Response Packet

```
{
  "status": "Success",
```

```
"message": "Guest token issued for testing.",
"data": {
  "token_id": "GT_97169b93f2a7ed495e78",
  "guest_token": "GUEST_ys7zwkcADNugAiUw_prE11LNb22rgk1b",
  "family_id": 12,
  "device_id": "ESP32_LOCK_001",
  "allowed_actions": [
    "UNLOCK"
  ],
  "expires_at": "2026-07-07 14:25:16",
  "max_uses": 1,
  "note": "Only this response shows the plaintext token. Database stores SHA-256 hash."
}
```

API → ESP32 封包規範

方向	規範
API → ESP32	本 API 不直接傳送封包至 ESP32。
後續關聯	App 使用 GUEST_ 呼叫設備控制 API 後，設備控制 API 才會產生 MQTT 控制封包。

Error Responses

HTTP 狀態	錯誤碼	說明
400	INVALID_JSON / MISSING_FIELD	JSON 格式錯誤或缺少必要欄位。
403	ROLE_DENIED / TOKEN_FORMAT_INVALID / TOKEN_EXPIRED / TOKEN_USED_UP	角色不符、訪客令牌格式錯誤、過期或次數耗盡。
404	DEVICE_NOT_FOUND / FAMILY_NOT_FOUND / TOKEN_NOT_FOUND	查無設備、場域或令牌。
409	DEVICE_REVOKED / DUPLICATE_RECORD	設備狀態衝突或不可重複操作。
500	DB_DRIVER_MISSING / INTERNAL_ERROR	資料庫驅動、SQL 或伺服器內部錯誤。

注意事項

- guest_token 明文只在 response 顯示一次，App 若遺失需重新核發。
- App 端不應顯示或傳遞 token_id 給訪客；token_id 只供 audit_logs 與 control_commands 紀錄。
- allowed_actions 應盡量最小化，例如只允許 UNLOCK，不要核發萬用控制令牌。

App 呼叫範例

App 端以 HTTPS POST 送出 JSON；本機測試可用 curl 或 printf 對應 CGI stdin。

```
POST /control_device/issue_guest_token_demo.py
Content-Type: application/json; charset=utf-8
```

```
{
  "payload": {
    "created_by": "admin_001",
    "family_id": 12,
    "device_id": "ESP32_LOCK_001",
    "allowed_actions": [
      "UNLOCK"
    ],
    "expires_in_minutes": 10,
    "max_uses": 1
  }
}
```

```
curl -X POST "http://localhost:8000/control_device/issue_guest_token_demo.py" \
-H "Content-Type: application/json" \
-d '{"payload": {"created_by": "admin_001", "family_id": 12, "device_id": "ESP32_LOCK_001", "allowed_actions": ["UNLOCK"], "expires_in_minutes": 10, "max_uses": 1}}'
```